25DCE026

Department of Computer Engineering

Practical - 10

Practical Title: Secure Login/Logout with Sessions, Role-Based Access, Timeout, and Remember-Me Token

Problem Definition: Develop secure login and logout functionality using PHP sessions. Verify password using `password_verify()`, regenerate session ID after login, restrict dashboard access, implement role-based redirection, session timeout, and optional secure remember-me token.

Theory :

1. Are sessions started and destroyed securely?

Yes. Sessions are initialized with `httponly: true`, `samesite: 'Lax'` cookie parameters. Logout calls `session_unset()`, `session_destroy()`, and explicitly expires the client-side session cookie.

2. Is password_verify() used correctly?

Yes. Authentication runs `password_verify($password, $user['password'])` which does a timing-attack-safe constant-time comparison against the stored bcrypt hash.

3. Is unauthorized dashboard access blocked?

Yes. `auth_check.php` middleware guards all protected routes. Unauthenticated users are redirected to `login.php?msg=unauthorized`; wrong-role users get `?msg=forbidden`.

4. Is session timeout implemented?

Yes. `$_SESSION['last_activity']` is tracked. After 15 minutes of inactivity (900 s), the session is destroyed and the user is redirected to `login.php?msg=timeout`.

5. Are admin and student users redirected to appropriate dashboards?

Yes. Upon successful authentication, administrators are redirected to `admin_dashboard.php` and students to `student_dashboard.php`.

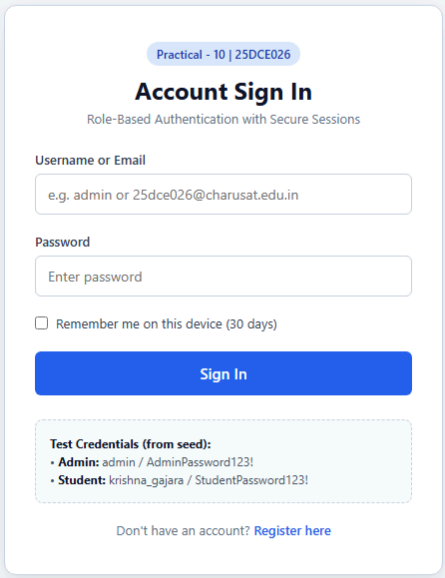
Implementation / Output / Result

```
if (password_verify($password, $user['password'])) {
    session_regenerate_id(true); // Prevent session fixation
    $_SESSION['user_id'] = $user['id'];
    $_SESSION['role']    = $user['role'];
    $_SESSION['last_activity'] = time();
    header("Location: " . ($user['role']==='admin' ? "admin_dashboard.php" :
"student_dashboard.php"));
}
```

25DCE026

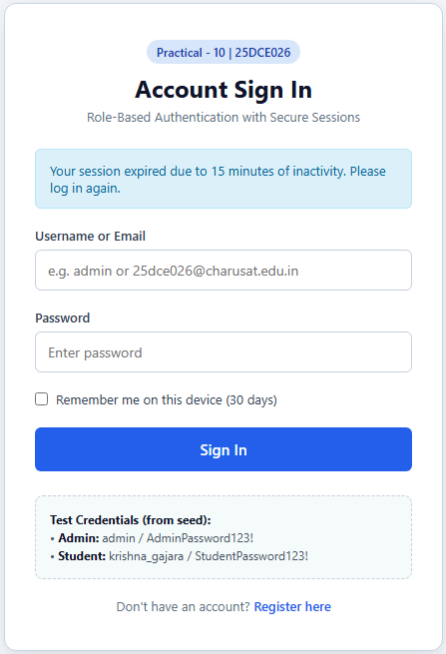
Output 1: Login Form with Remember-Me Option

Live browser screenshot: Sign-In form with Username/Email, Password field, and 'Remember me on this device' checkbox.



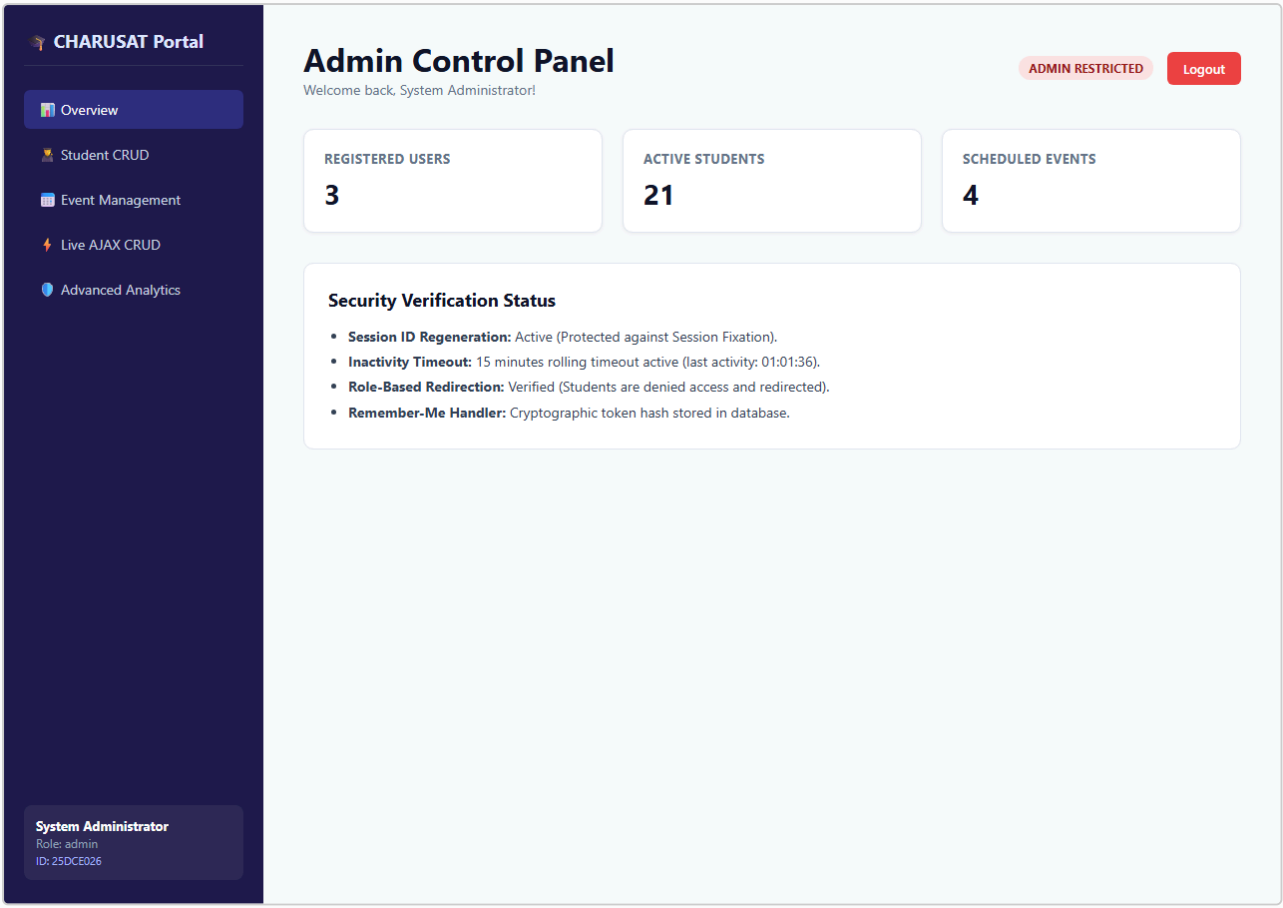
Output 2: 15-Minute Inactivity Session Timeout Banner

Live browser screenshot: Info banner — 'Your session expired due to 15 minutes of inactivity. Please log in again.'



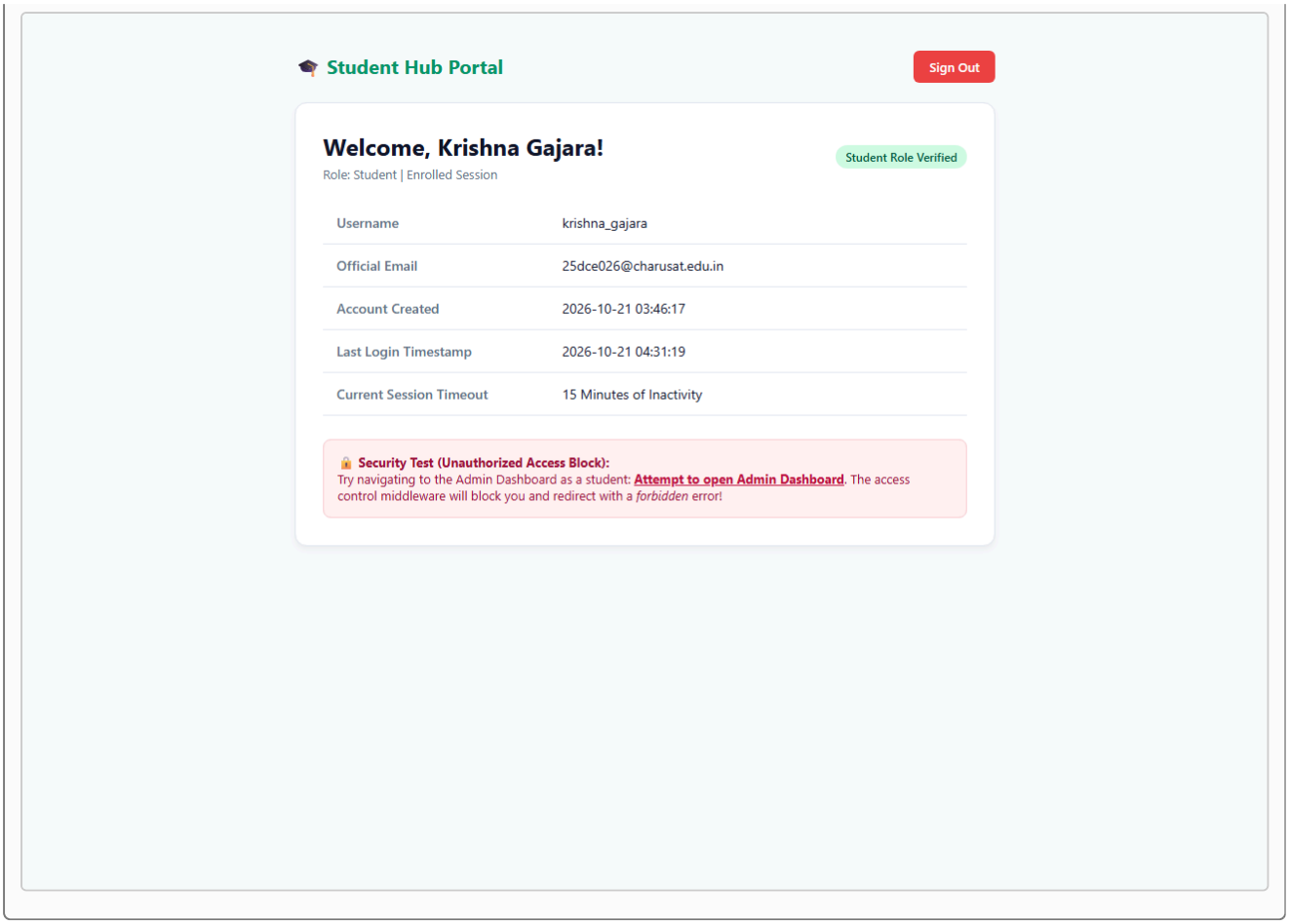
Output 3: Admin Dashboard after Successful RBAC-Guarded Login

Live browser screenshot: Admin dashboard with greeting, role badge, and logout button — only accessible to admin role.



Output 4: Student Dashboard after Role-Based Redirection

Live browser screenshot: Student dashboard showing student-specific content — admin routes are blocked for this session.



GitHub Repository Link:
https://github.com/25dce026-krishna/StudentHub

Learning Outcomes:

- Implemented secure PHP session lifecycle management and cookie configuration.
- Verified passwords securely using constant-time `password_verify()` comparisons.
- Protected sessions against fixation exploits using `session_regenerate_id(true)`.
- Designed Role-Based Access Control (RBAC) middleware for restricting protected pages.
- Engineered rolling session inactivity timeouts (15 minutes) with automatic redirection.
- Implemented persistent Remember-Me authentication using cryptographic database token hashes.
- Handled secure session destruction, cookie clearance, and audit logging on logout.